



Cyber.SoHo Educational Hub — 420-1C1-DW Preventative Monitoring

Class 6 — Topic 2 (continued): Understanding the Network to Be Monitored

Lesson 2.3 — Organizational and operational constraints of the network

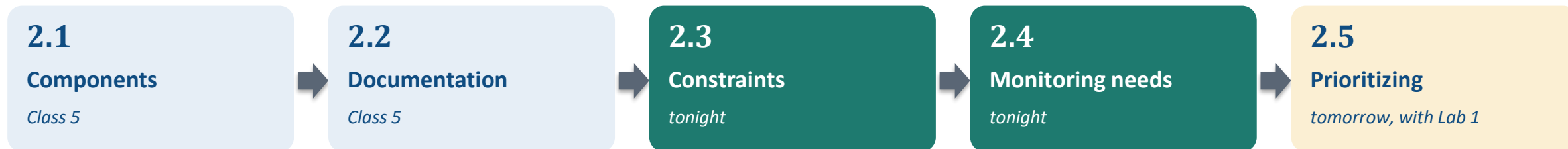
Lesson 2.4 — Identifying monitoring (surveillance) needs

Thursday, September 24, 2026 — 6:00 to 10:00 pm, online

Asen Grozdanov — LEA.D8 Cybersecurity: Prevention and Intervention (AEC), Dawson College
Competency EZ01, element 2 — performance criteria 2.1 and 2.2



T2 Where we are in Topic 2 — and what Class 5 gave us



What Class 5 established (Lessons 2.1 and 2.2)

- **Servers, workstations and network equipment** are the three kinds of components; each one is an asset, something of value that must be protected.
- **The topology diagram** shows how the components are connected; **the inventory** lists every asset with its name, address, role and owner.
- **Monitoring starts from documentation**: you cannot watch what you have not identified.
- **Tonight** we add the two missing pieces of the plan: the limits we must respect (2.3) and the things we must watch (2.4).



What you will be able to do after this class

- **Explain** the difference between an organizational constraint and an operational constraint, with three examples of each.
- **Examine** a documented network and record its constraints in a constraint register (performance criterion 2.1).
- **Define** a monitoring need precisely: asset, event, observable, data source, detection time objective.
- **Derive** the monitoring needs of a small network with a repeatable method and record them in a needs register (performance criterion 2.2).
- **Bring** both registers to Lab 1 tomorrow, where they become two sections of your monitoring plan.

Competency EZ01

Monitor a computer network from a cybersecurity perspective.

Element 2: analyze the topology of the network.

2.1 thorough examination of the constraints.

2.2 identification of surveillance needs.

Coming evaluations

Lab 1 (5 %) — Fri Sept 25

Quiz 2 (5 %) — Sat Sept 26, cumulative

Midterm (25 %) — Thu Oct 1, in class, Topics 1 to 3



The network we work on: Ébénisterie Val-des-Pins Inc. (1/2)

- **Activity:** custom cabinet making, Laval, Québec — 22 employees; owner Marie-Josée Tremblay approves all spending.
- **Office:** 6 workstations (WS-01 to WS-06), file server SRV-FILE-01, backup NAS (Network Attached Storage) NAS-01, printer PRN-01.
- **Workshop:** one computer, CNC-PC-01, drives two CNC (Computer Numerical Control) machines; old operating system; vendor support contract.
- **Network equipment:** firewall FW-01 (100 Mbit/s Internet link), managed switch SW-01, unmanaged switch SW-02, access point AP-01 with an office and a guest network.
- **Outside:** cloud e-mail and accounting (SaaS, Software as a Service), website hosted by a third party, one sales laptop on a VPN (Virtual Private Network).
- **People and money:** no internal IT staff; external provider 6 h/month; CAD 1,500 approved for monitoring this year.
- **Hours:** office 8:00–17:00, workshop 7:00–16:30 weekdays, Saturday mornings Sept–Nov; a CNC job runs up to 6 h without interruption.
- **Data:** customer names, addresses and payment details; employee files (Law 25); drawings and quotes (trade secrets).

Fictional, on purpose

Name, people, addresses and numbers are invented for this course.

Legal Notice, section 6.4: use this organization or another invented one — never a real employer or real people.

Addresses (private ranges)

Office 10.20.1.0/24

Workshop 10.20.2.0/24

Guest Wi-Fi 10.20.9.0/24

Firewall 10.20.0.1

CNC-PC-01 10.20.2.50



The network we work on: Ébénisterie Val-des-Pins Inc. (2/2)

Ébénisterie Val-des-Pins Inc. (fictional) — network schematic used in Classes 5 to 7

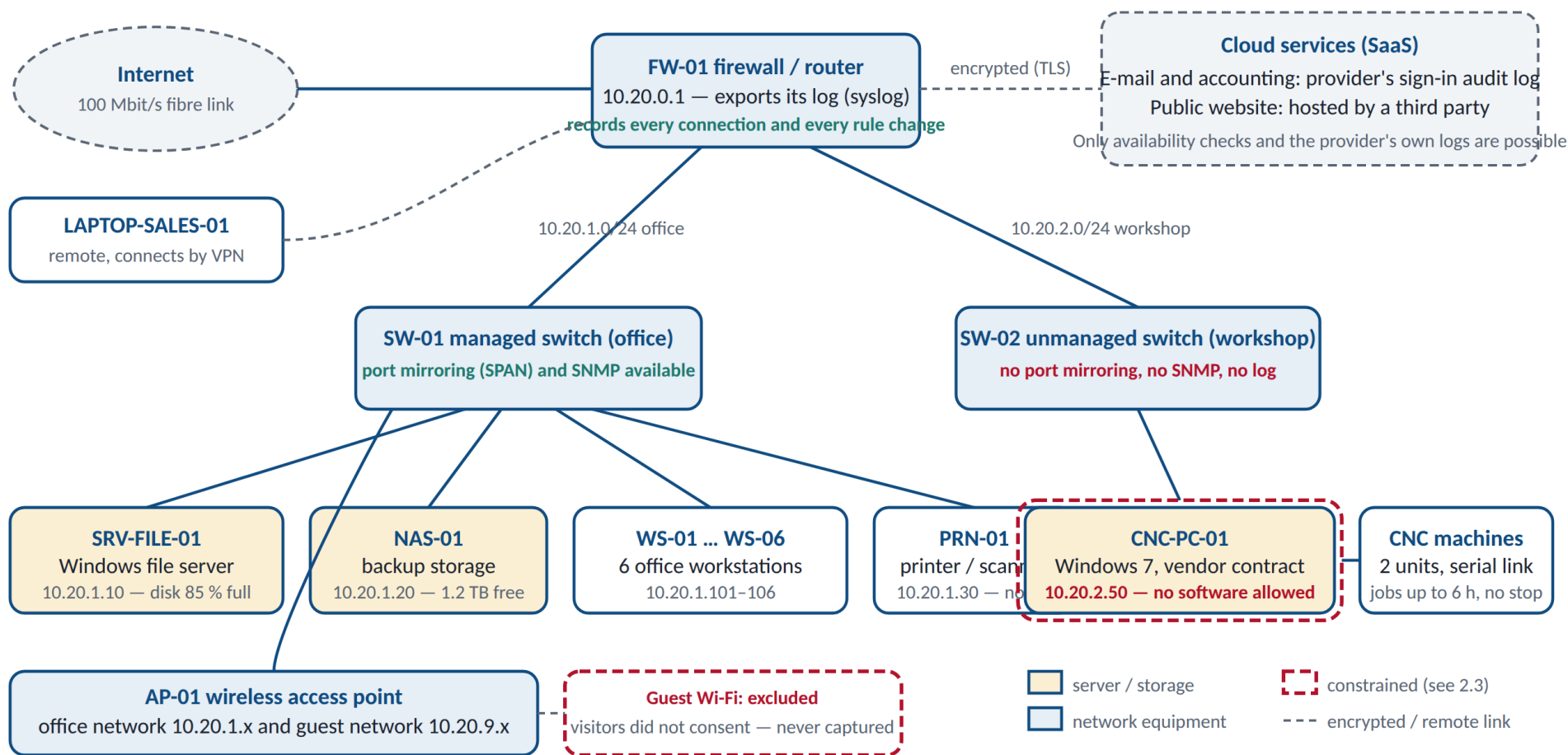


Figure 1 — Red dashed outlines: parts that carry a constraint (Lesson 2.3). Green labels: features that make monitoring possible.



Agenda of the lecture block (60 minutes)

Part	Content	Minutes
Opening	Objectives, recap of Class 5, the fictional organization	8
Lesson 2.3	What a constraint is; organizational and operational constraints; why they matter; the constraint register; worked example, program, schematic	24
Practice 2.3	Flash cards, 4 multiple-choice and 2 multiple-select questions	3
Lesson 2.4	What a need is; where needs come from; the six-question method; categories; coverage and gaps; writing a need; worked example, program, schematic	20
Practice 2.4	Flash cards, 4 multiple-choice and 2 multiple-select questions	3
Bridge	What to bring to Lab 1 tomorrow; Quiz 2 on Saturday	2
Total		60

The rest of tonight's session (after the 60-minute block) is guided practice: start your own constraint register and needs register for Lab 1, and ask questions.



The rules of this class — and of every lab

- **Authorization is the rule that governs everything else** (Legal Notice, section 6.1): you apply these techniques only to systems you own or are authorized in writing to work on.
- **Your Authorized Lab Environment is the only network you monitor** (sections 6.4 and 7.2): isolated virtual machines, fictional data, snapshots before every exercise.
- **Never capture on a network you share with other people** — home Wi-Fi, campus Wi-Fi, a workplace. Knowingly intercepting private communications may be an offence (Criminal Code, section 184).
- **Never install a collector or agent on a device that belongs to someone else** — including “to help”.
- **Treat every log and capture as personal information** about the people who used those systems (section 6.7): keep the minimum, delete it when the exercise is marked.

Criminal Code of Canada

- s. **342.1** unauthorized use of a computer (up to 10 years)
- s. **342.2** possession of a device to commit an offence
- s. **430(1.1)** mischief in relation to computer data
- s. **184** interception of private communications

Full terms

Cyber.SoHo Legal Notice, Terms of Use and Acceptable Use Policy, v2.0 (September 13, 2026):

<https://cyber-soho.github.io/prevmon/00.01.cyber-soho-legal.html>



Lesson 2.3

Organizational and operational constraints of the network

Performance criterion 2.1 — thorough examination of the organizational and operational constraints of the network. What limits us: money, people, rules, laws, contracts, schedule — and links, disks, old machines, equipment features, encryption, clocks.



2.3.1 What a constraint is

Constraint

A condition, imposed by the organization or by the way its network operates, that limits what monitoring can be done, how it can be done, when, where, by whom, and at what cost.

- **A constraint is a fact, not an opinion.** It can be traced to a document, a contract, a law, a measurement or a decision of the owner.
- **A map tells you what exists.** It does not tell you what you are allowed to do, what the equipment is able to do, or what the organization can afford.
- **Constraints come before any tool.** A plan that ignores them is refused by the owner, breaks the network it should protect, or breaks the law.

Two families

Organizational — from the organization as a business: money, people, rules, contracts, laws, schedule, authorization.

Operational — from the technical way the network runs: capacity of links and disks, equipment capabilities, systems that cannot stop, segmentation, encryption, clocks.



2.3.1 Two distinctions you will use all evening

Constraint or requirement?

A requirement states what monitoring must achieve: “detect a failed backup within 12 hours” (Lesson 2.4).

A constraint states what monitoring must respect while achieving it: “monitoring data is kept 90 days at most”.

Hard or soft?

Hard — cannot be changed by the monitoring project: a law, a signed contract, a safety rule on a machine.

Soft — could be removed later with money, time or a decision: an unmanaged switch, this year’s budget.

- **Both kinds are recorded.** The “type” column of the register tells them apart.
- **Only soft constraints become recommendations** in Lesson 6.5 (Recommending tools and improvements).
- **Hard constraints shape the adaptations:** when a hard constraint blocks an activity, you change the method, never the rule.



2.3.2 Organizational constraints (1/2)

- **Budget and procurement** — how much money, for what period, who approves, is new hardware allowed?
 - Val-des-Pins: CAD 1,500 this year; the owner approves every purchase; no new server.
- **People and skills** — who operates the monitoring, how many hours, who answers an alert at night or on the weekend?
 - No internal IT staff; external provider 6 h/month; nobody on call after hours.
- **Policies and rules** — security policy, AUP (Acceptable Use Policy), retention policy, change management: approval, change window, rollback plan.
 - Any change to a production system needs the owner's written approval and an agreed window; monitoring data kept 90 days at most.
- **Legal and regulatory** — which laws govern the data the network carries and the people who use it?
 - Personal information under Law 25; capture of communications (Criminal Code s. 184); software installation without consent (CASL s. 8).

How to collect them

Ask the question, write the answer as a fact with a number or a document behind it, and note who told you.

Sources: the owner (money, tolerance for disruption, authorization), the users (schedule, peaks), the provider (hours, skills), the vendor (what the contract forbids).

This is the checklist you will use in Lab 1.



2.3.2 Organizational constraints (2/2)

- **Contracts and agreements** — support contracts, the SLA (Service Level Agreement) of each provider, the terms of cloud services.
 - The CNC vendor contract voids the warranty if third-party software is installed on CNC-PC-01; the cloud provider forbids scanning but offers a sign-in audit log.
- **Schedule and tolerance for disruption** — when does the organization work, when are its peak periods, how much interruption can it accept?
 - Workshop 7:00–16:30, Saturday mornings Sept–Nov; a 6-hour CNC job is never interrupted; the office tolerates 30 minutes after 17:00 with notice.
- **Authorization and ownership** — who owns each system and who can authorize monitoring on it, in writing?
 - The owner authorizes everything inside the building; the cloud provider owns the cloud service; the vendor owns the CNC software. Annex D of the Notice is the template.
- **Confidentiality of the monitoring data** — who may see alerts, logs and captures, where are they stored, when are they deleted?
 - Only the owner and the provider’s technician; stored on NAS-01; deleted after 90 days.

Performance criterion

“Respect for the confidentiality of the monitoring data collected” is one of the criteria of the whole competency EZ01.

It starts here, in the register.

Annex D

Written authorization to monitor, scan or test a system — the template you must use before touching any real organization’s network (Notice, section 7.9).



The legal constraints of monitoring in Québec

- **Law 25** (Act respecting the protection of personal information in the private sector, CQLR c. P-39.1): customer and employee files are personal information; collect the minimum, inform the people concerned, keep it no longer than needed.
- **The CAI** (Commission d'accès à l'information du Québec) supervises these obligations and receives confidentiality-incident notifications.
- **PIPEDA** (Personal Information Protection and Electronic Documents Act) — the federal private-sector privacy law; may apply to interprovincial activity.
- **Criminal Code, s. 184** — knowingly intercepting a private communication; capturing other people's network traffic can be interception.
- **CASL, s. 8** (Canada's Anti-Spam Legislation) — installing a computer program on someone's device without express consent.

The course rule is simpler and stricter

You monitor systems and events, never people, and only inside your own lab.

Legal Notice, section 7.2.

Official sites (links in the HTML page)

legisquebec.gouv.qc.ca

cai.gouv.qc.ca

priv.gc.ca

laws-lois.justice.gc.ca

ised-isde.canada.ca (CASL)



2.3.3 Operational constraints (1/3): capacity

- **Link capacity (bandwidth)** — monitoring traffic (log forwarding, polling, mirrored traffic) shares the links with production traffic; a mirrored copy of a busy link can exceed the capture port.
 - Internet link 100 Mbit/s; office and workshop joined by one 100 Mbit/s cable; ceiling of 5 Mbit/s for monitoring traffic.
- **Storage capacity** — every log entry and every captured packet occupies disk for the whole retention period.
 - SRV-FILE-01 is 85 % full and cannot receive logs; NAS-01 has 1.2 TB (terabytes) free.
- **Processing capacity of hosts** — a monitoring agent (a program installed on a computer to collect its logs or metrics) uses CPU (Central Processing Unit) time and RAM (Random Access Memory).
 - Workstations can take a light agent; the file server must not lose more than 5 % of its processor capacity.

The storage formula

bytes per event
× events per second
× 86,400 seconds per day
× retention days
÷ 1,000,000,000 = GB

Firewall log of Val-des-Pins

$300 \text{ B} \times 25/\text{s} \times 86,400 \times 90 \text{ d}$

≈ 58 GB

A continuous capture uses its data rate instead: 1 Mbit/s
= 125,000 bytes per second.



2.3.3 Operational constraints (2/3): what cannot stop or change

- **Availability requirements** — some systems cannot be stopped, rebooted or modified except during a maintenance window agreed with the owner.
 - CNC-PC-01 cannot be touched while a job runs (up to 6 hours); the file server is restarted only after 17:00 with notice.
- **Legacy and unsupported systems** — old operating systems and embedded devices (printers, machine controllers, cameras) accept no agent, produce no usable log, support only old protocols.
 - CNC-PC-01 runs Windows 7, no longer supported by its publisher; PRN-01 produces no log at all.
- **Features of the network equipment** — port mirroring (SPAN, Switched Port Analyzer), SNMP (Simple Network Management Protocol) and log export (syslog) exist only on equipment that supports them.
 - SW-01 supports SPAN and SNMP; SW-02 is unmanaged and supports none; FW-01 exports its log by syslog.

Maintenance window

A period agreed with the owner during which a system may be stopped or modified.

Val-des-Pins: weekdays after 17:00, Saturdays after 12:00.

Three device terms

SPAN copies the traffic of one switch port to another for capture.

SNMP reads counters (traffic, errors, load) from equipment.

syslog sends log messages to a collector.



2.3.3 Operational constraints (3/3): what limits what we can see

- **Segmentation and filtering** — firewalls and VLANs (Virtual Local Area Networks) separate zones; monitoring traffic must be allowed through (syslog on UDP port 514, SNMP on UDP ports 161 and 162); remote sites and users arrive over a WAN (Wide Area Network) link or a VPN.
- **Encryption and cloud services** — traffic protected by TLS (Transport Layer Security) shows who talks to whom, when and how much, not the content; for a cloud service, only what the provider exposes can be monitored.
 - E-mail and accounting are cloud services: rely on the provider's sign-in audit log.
- **Time synchronization** — events from different devices can be compared only if their clocks agree; NTP (Network Time Protocol) keeps them synchronized.
 - FW-01 and SRV-FILE-01 differ by 4 minutes: enable NTP before correlating logs (Lab 2).
- **Physical and environmental** — where the collector sits, its power, its cooling, who can reach it.

Security issue or performance issue?

Lesson 1.5 taught you to tell them apart.

Operational constraints are where the two meet: a monitoring setup that ignores link and disk capacity creates the performance problem it was meant to detect.

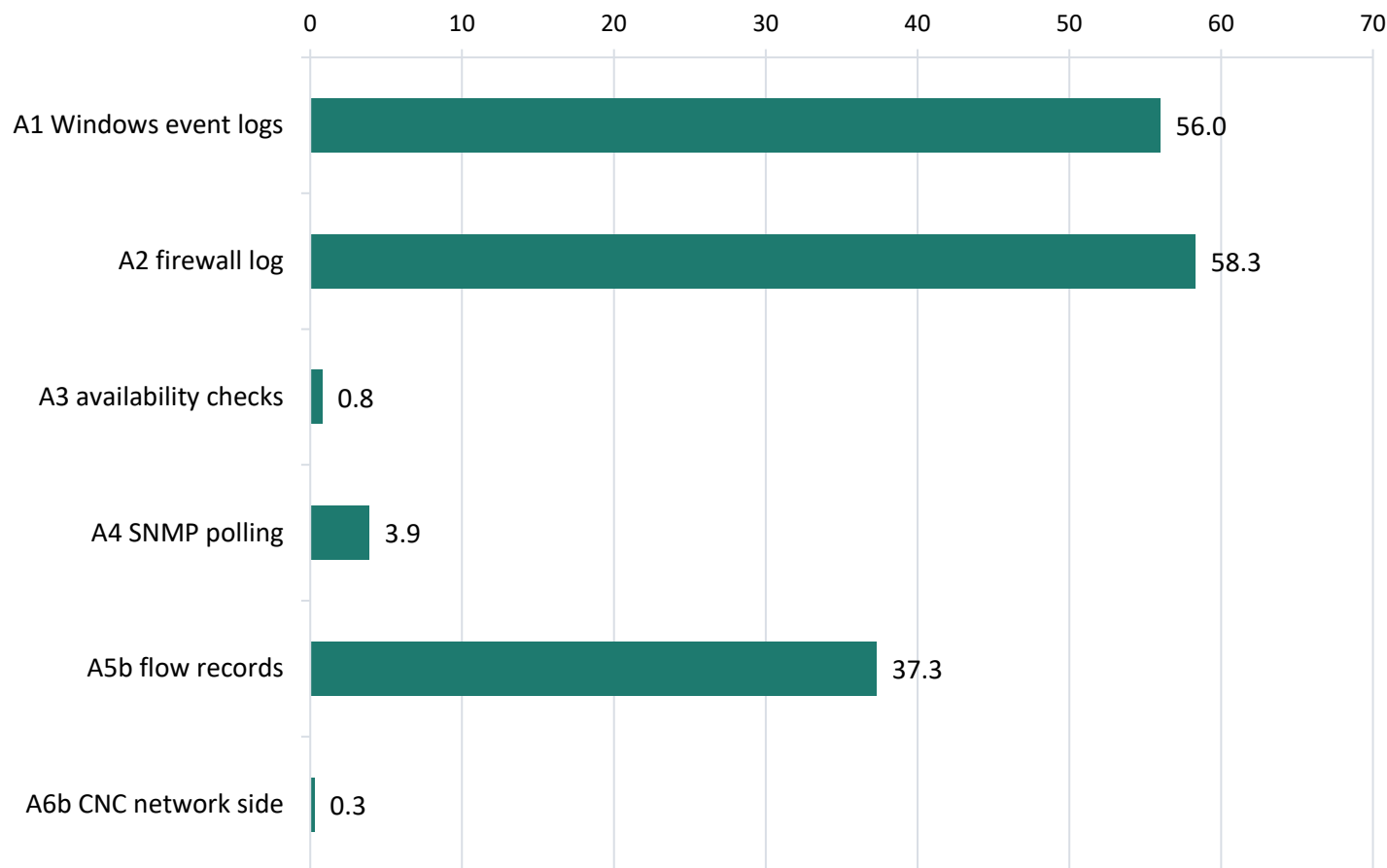
Lesson 6.2 returns to this: reducing the impact of monitoring on network performance.



2.3

Storage for 90 days: the candidate activities of Val-des-Pins

Storage needed for 90 days (GB) — accepted activities



Read the numbers

157 GB

used by the accepted set, of 1,200 GB free on NAS-01 (13 %)

29,160 GB

what A5, full packet capture at 30 Mbit/s for 90 days, would need — 24 times the NAS

A5 was replaced by A5b, flow records from the firewall: 37 GB. The goal is kept, the method changes.



2.3.4 Why constraints matter for monitoring

1

Monitoring consumes resources

Collecting, transporting and storing data costs bandwidth, disk, processor time and money. The operational constraints tell you how much you can spend of each.

2

Monitoring collects data about people

A log of connections is a record of what employees and visitors did. The legal constraints tell you what you may collect, whom you must inform, and how long you may keep it.

3

Monitoring changes systems

Installing an agent, enabling log export or configuring a mirror port is a change to a production system. Change management tells you when and how, and how to undo it.

4

Monitoring without authorization is an offence, whatever the intention

Section 6.1 of the Legal Notice: only systems you own or are authorized in writing to work on. The authorization constraint is the first line of every register.

For the labs: your Authorized Lab Environment is the only network you monitor. No promiscuous mode on a shared network, no collector on someone else's device, no capture on college or home Wi-Fi "to have real data" (Annex E).



2.3.5 Examining the constraints: four sources

1

Documentation

Inventory, topology diagram, contracts, policies, provider terms — what Lesson 2.2 taught you to read.

2

Interviews

The owner (money, disruption, authorization), the users (schedule, peaks), the provider (hours, skills), the vendor (what the contract forbids).

3

Observation

Model and features of each device, free disk space, link speeds, whether NTP is configured.

4

Measurement

Events per second produced by a device; traffic crossing a link at the busiest hour — the beginning of the baseline of Topic 3.

- **“Thorough examination”** (performance criterion 2.1) means you used every source available — not that you guessed carefully.
- **Everything you find goes into one table**, the constraint register, with fixed columns so that every student’s register can be compared with every other’s (next slide).



2.3 2.3.5 The constraint register: eight fixed columns

Column	What goes in it
ID	C-01, C-02, ... so that other documents can refer to the constraint.
Family	Organizational or operational.
Category	One of the categories of 2.3.2 and 2.3.3.
Description	The fact, with its number or its document: “NAS-01 has 1.2 TB free”, not “storage is limited”.
Source	Who told you, or which document says it.
Type	Hard (cannot be changed by the project) or soft (could be changed later).
Impact	1 minor — 2 limits a choice — 3 blocks an activity.
Adaptation	How the monitoring plan will respect it.

First deliverable of Lab 1

Section 3, “Constraints”, of your monitoring plan is this register.

Template: CSV download on the HTML page.

Tomorrow, Lesson 2.5

The register is one of the two inputs of prioritization; the other is the needs register of Lesson 2.4.



2.3.6 Worked example: the register of Val-des-Pins (1/2)

ID	Family — category	Description (fact)	Type / impact	Adaptation in the plan
C-01	Organizational — Budget	CAD 1,500 approved this year; no new server.	Soft / 2	Free tools; one used collector computer (CAD 350); logs on NAS-01.
C-02	Organizational — People and skills	External provider 6 h/month; nobody on call after hours.	Soft / 3	Keep 1.5 h/month for reacting to alerts; few alert rules; alerts by e-mail to provider and owner.
C-03	Organizational — Legal and privacy	Customer and employee personal information (Law 25); data kept 90 days at most.	Hard / 2	Monitor systems and events, not people; written policy communicated; access for two persons.
C-04	Organizational — Contract	CNC vendor contract voids the warranty if third-party software is installed on CNC-PC-01.	Hard / 3	No agent on CNC-PC-01; watch it from the network side.
C-05	Organizational — Authorization and policy	Only the owner authorizes changes; guest Wi-Fi traffic must never be captured.	Hard / 3	Written authorization (Annex D) first; guest network excluded from every capture and log.
C-06	Operational — Availability	CNC jobs run up to 6 h; no installation or restart during production.	Hard / 2	Maintenance window: weekdays after 17:00 or Saturdays after 12:00.

Full register with the “source” column: CSV download on the HTML page (06_constraint_register_valdespins.csv).



2.3.6 Worked example: the register of Val-des-Pins (2/2)

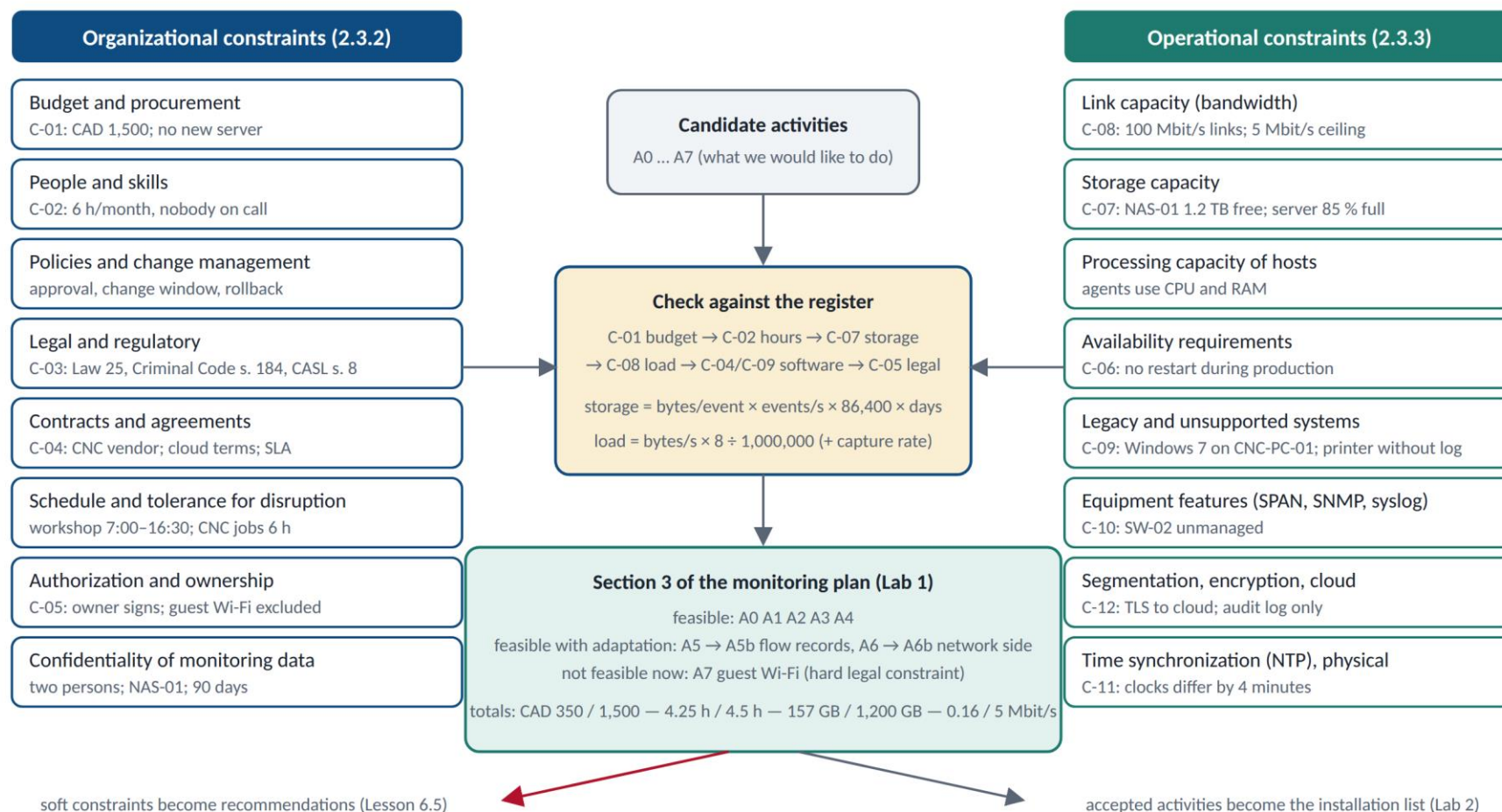
ID	Family — category	Description (fact)	Type / impact	Adaptation in the plan
C-07	Operational — Storage capacity	SRV-FILE-01 disk 85 % full; NAS-01 has 1.2 TB free.	Soft / 2	All monitoring data on NAS-01; size every activity with the storage formula.
C-08	Operational — Link capacity	Internet 100 Mbit/s; office–workshop 100 Mbit/s; monitoring ceiling 5 Mbit/s.	Soft / 2	No continuous full packet capture; flow records from the firewall instead.
C-09	Operational — Legacy system	CNC-PC-01 runs Windows 7 (unsupported); no modern agent possible.	Hard / 3	Network-side monitoring; recommend isolating the workshop network (6.5).
C-10	Operational — Equipment features	SW-02 (workshop) is unmanaged: no SPAN, no SNMP, no log.	Soft / 2	Workshop traffic seen only where it crosses FW-01; recommend a managed switch.
C-11	Operational — Time synchronization	Device clocks differ by up to 4 minutes; no NTP.	Soft / 2	Enable NTP on every device in Lab 2 before the baseline.
C-12	Operational — Encryption and cloud	E-mail and accounting in the cloud over TLS; provider offers a sign-in audit log.	Hard / 2	Use the provider’s audit log and availability checks; never inspect content.

Six operational lines: capacity, links, legacy, equipment features, clocks, encryption — every one has a number or a device model behind it.



Figure 2 — The constraint map: what the plan must respect

Figure 2 — Constraint map: what the monitoring plan must respect



Candidate activities enter at the top; each is tested against both families; what leaves at the bottom is section 3 of the plan. Download: SVG / PNG on the HTML page.



2.3

Real-life example: “Can we do that here?”

Task

You are the provider’s technician. The owner gives you the facts of the register. You have eight monitoring activities you would like to set up. For each one: feasible as written, feasible after an adaptation, or not feasible now — with running totals of money, hours, storage and load.

Relation to the lesson

Performance criterion 2.1 in practice: the constraints are examined first, and every activity is tested against them before any tool is chosen. Tools come in Topic 3.

Deliverable and future labs

Lab 1 (Sept 25): section 3 “Constraints” = register + verdict table.
Lab 2 (Oct 3): the accepted activities are the installation list.
Lab 3 (Oct 16): storage and load figures start the optimization.

- **Monday morning:** one hour with the owner (budget, hours, the guest rule), then a walk through the building: NAS free space, the unmanaged switch, the vendor sticker on the CNC computer, the firewall’s syslog option.
- **Back at the desk:** list what could be done (next slide) and apply the register — that is exactly what Program 1 does.



2.3 The eight candidate activities (input of Program 1)

ID	Candidate activity	Cost	Hours / month	Data produced	Software on	Segment captured
A0	One small used computer as collector	CAD 350	1.0	—	—	—
A1	Windows event logs of SRV-FILE-01 and WS-01..06	0	1.0	8 events/s × 900 B	server, workstations	—
A2	Firewall connection log exported to the collector	0	0.5	25 events/s × 300 B	—	—
A3	Availability checks every minute (servers, CNC PC, printer, Internet link)	0	0.5	0.5 events/s × 200 B	—	—
A4	SNMP polling of SW-01 and FW-01 every 60 s	0	0.5	2 events/s × 250 B	—	—
A5	Full packet capture of the Internet link, 24 h a day	CAD 900	4.0	30 Mbit/s continuous	—	Office LAN
A6	Monitoring agent on CNC-PC-01	0	0.5	1 event/s × 900 B	CNC-PC-01	—
A7	Capture of the guest Wi-Fi traffic	0	0.5	5 Mbit/s continuous	—	Guest Wi-Fi

Two lighter versions exist: A5b — flow records (connection summaries) from FW-01 instead of packets; A6b — availability check plus firewall log instead of an agent on CNC-PC-01.



2.3

Program 1 — how it decides

- **FACTS** — the limits of the register: budget, hours and reserve, NAS space, load ceiling, retention, forbidden devices, forbidden segments.
- **ACTIVITIES and ADAPTATIONS** — what each activity costs; two lighter versions.
- **find_problems** — tests every constraint in order and lists the violated ones.
- **commit** — adds an accepted activity to the running totals.
- **The loop** — no problem: feasible; problem and a lighter version that passes: feasible with adaptation; otherwise: not feasible now.
- **Output** — one verdict line per activity, the totals, and constraint_check_result.csv.
- Run it step by step on the HTML page: Start / Pause, Next step, Restart, Copy, Download.



The simulator while A5 is checked: hours, storage and load turn red at once.

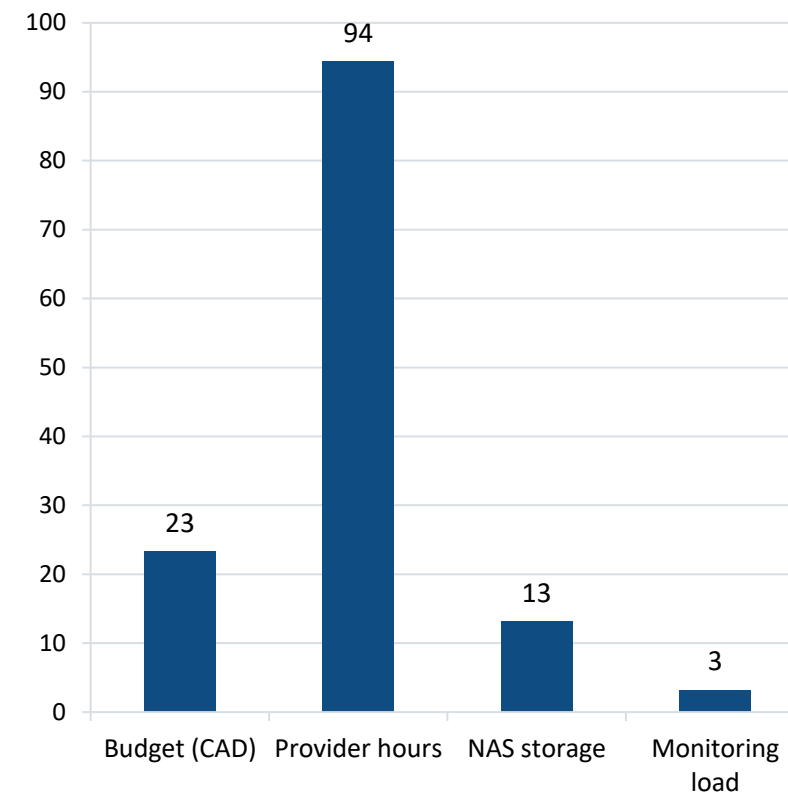


2.3

Program 1 — the verdicts

ID	Verdict	Constraints hit
A0	feasible	—
A1	feasible	—
A2	feasible	—
A3	feasible	—
A4	feasible	—
A5	feasible with adaptation → A5b flow records	C-02 hours, C-07 storage, C-08 load
A6	feasible with adaptation → A6b network side	C-04/C-09 no software on CNC-PC-01
A7	not feasible now (hard legal constraint)	C-05 guest Wi-Fi + C-02, C-07, C-08

Accepted set: share of each limit used (%)



Totals: CAD 350 of 1,500 — 4.25 h of the 4.5 h available (6 h minus 1.5 h reserve for reacting to alerts) — 157 GB of 1,200 — 0.16 Mbit/s of 5. The tightest limit is people, not money.



Videos for Lesson 2.3 — under 15 minutes each



Change Management — CompTIA Security+ SY0-701 — 1.3

Professor Messer, YouTube, 11 min 22 s

Watch for: the approval process, the change window, the backout (rollback) plan, the test before the change. Installing a monitoring tool is a change like any other (Lab 2).

<https://www.youtube.com/watch?v=48wRbMdHFVI>



Infrastructure Considerations — CompTIA Security+ SY0-701 — 3.1

Professor Messer, YouTube, 13 min 48 s

Watch for: cost, compute capacity, availability and resilience, responsiveness, and whether equipment can be patched or replaced. Map each to a line of the Val-des-Pins register.

https://www.youtube.com/watch?v=Ap3Z_0ZdqpQ

Links verified on September 23, 2026. Check any link you did not type yourself with VirusTotal before opening it (Legal Notice, Annex C).



Key terms of Lesson 2.3 (the flash cards)

Term	What it means
Constraint	A condition, from the organization or from the way the network operates, that limits what monitoring can be done, how, when, where, by whom and at what cost. A fact traceable to a document, contract, law, measurement or decision.
Organizational vs operational	Organizational: budget, people and skills, policies, laws, contracts, schedule, authorization, confidentiality. Operational: link and storage capacity, host capacity, availability, legacy systems, equipment features, segmentation, encryption, clocks, physical conditions.
Storage formula	$\text{bytes per event} \times \text{events per second} \times 86,400 \times \text{retention days} \div 1,000,000,000 = \text{GB}$. Example: $300 \text{ B} \times 25/\text{s} \times 86,400 \times 90 \text{ d} \approx 58 \text{ GB}$. A capture uses its data rate: $1 \text{ Mbit/s} = 125,000 \text{ B/s}$.
Hard vs soft	Hard cannot be changed by the project (law, contract, safety rule); soft could be removed later (unmanaged switch, this year's budget). Both recorded; soft ones become recommendations (6.5).
Guest Wi-Fi rule	Refused even with unlimited storage: the visitors did not consent; knowingly capturing private communications may be interception (Criminal Code s. 184); Notice section 7.2 forbids it in every course.



Check yourself — Lesson 2.3 (1/2)

1. Which of the following is an organizational constraint?

- a) SW-02 has no port mirroring
- b) The CNC vendor contract forbids software on CNC-PC-01
- c) The disk of SRV-FILE-01 is 85 % full
- d) The device clocks are not synchronized

2. 25 events/s of 300 bytes, kept 90 days — storage needed?

- a) about 5.8 GB
- b) about 58 GB
- c) about 580 GB
- d) about 5.8 TB

3. Why does the plan refuse to capture the guest Wi-Fi?

- a) The access point is on an unmanaged switch
- b) The visitors did not consent; capture may be interception (s. 184); Notice 7.2 forbids it
- c) It would exceed the NAS storage
- d) Guest traffic is always encrypted and useless

Answers and explanations: in the speaker notes, and on the HTML page (“Check my answer”).



Check yourself — Lesson 2.3 (2/2)

4. Which statement about the constraint register is correct?

- a) It lists the tools that will be installed
- b) It contains only the constraints that can be removed
- c) It records each limit as a fact with its source, its impact and the adaptation chosen
- d) It replaces the monitoring plan

5. Which are operational constraints? (select all that apply)

- a) SW-02 unmanaged: no SPAN, SNMP or log
- b) CAD 1,500 approved this year
- c) One 100 Mbit/s cable joins office and workshop
- d) Monitoring data kept 90 days at most
- e) A 6-hour CNC job must not be interrupted
- f) The provider gives 6 hours per month

6. Which are correct adaptations when a constraint blocks an activity? (select all that apply)

- a) Watch CNC-PC-01 from the network side instead of an agent
- b) Install the agent anyway, because it is for security
- c) Replace full packet capture with flow records
- d) Capture the guest Wi-Fi only at night
- e) Schedule installations in an agreed maintenance window
- f) Test the collector on the college network first

Answers and explanations: in the speaker notes, and on the HTML page (“Check my answer”).

Lesson 2.4

Identifying monitoring (surveillance) needs

Performance criterion 2.2 — identification of surveillance needs.

What we must watch: one asset, one event, one observable, one data source, one detection time objective — before any tool.



2.4.1 What a monitoring need is

Monitoring need

A precise statement of one thing that must be observed on one asset, for one security or operational reason, together with the sign that would reveal it, the place where that sign is recorded, and the time within which it must be noticed.

- **Lesson 2.3 told us what we must respect; this lesson tells us what we must watch.** The competency says “surveillance need”; we say “monitoring need” — the same thing.
- **A need is written before any tool is chosen.** The tool comes afterwards, in Topic 3, to satisfy the need.
- **A need can be read as one sentence** built from six answers (2.4.3). If a row of the register cannot be read that way, an answer is missing.

One sentence, one need

“N-01 — On SRV-FILE-01 (criticality 3), detect password guessing by observing 10 or more failed logons from one source within 5 minutes in the Windows Security event log, within 15 minutes; notify the provider and the owner.”



2.4.1 Five terms that make a need precise

Term	Meaning	Example
Event	Something that happens on a system and can be recorded.	A logon, a connection, a job that finishes, a device that stops answering.
Observable (indicator)	The recordable sign that the event happened, written with a number or a pattern so two people read it the same way. An IoC (Indicator of Compromise) when the event is an intrusion.	“10 or more failed logons from one source within 5 minutes”, not “too many failed logons”.
Data source	Where the observable is recorded.	Windows event log, firewall log, availability check, antivirus console, provider audit log, DHCP lease log, SNMP counters, NAS report.
Detection time objective	The longest acceptable delay between the event and the moment someone knows. The delay actually achieved is the MTTD (Mean Time To Detect).	15 minutes for password guessing; 12 hours for a failed backup.
Criticality	How much the asset needs the requirement the event would harm: 1 to 3 for each of C, I, A (Confidentiality, Integrity, Availability).	SRV-FILE-01: C 3, I 3, A 3.

Need, alert, tool

The need is the requirement: “detect a failed backup within 12 hours”.

The alert is the message a tool produces when the observable crosses its threshold (Lesson 3.5).

The tool is the program that reads the data source and produces the alert (Lesson 3.2).

“Install an antivirus” names a tool and says nothing about what must be detected.



2.4.2 Where monitoring needs come from (1/2)

- **1. The security requirements of each asset.** Topic 1 taught you to rate C, I and A. An asset rated 3 for confidentiality needs to be watched for anything that would disclose its data; rated 3 for availability, for anything that would stop it.
- **2. The threats of Lesson 1.3.** For each attack type you know — password guessing, malware, data theft, denial of service, unauthorized change — ask what it would look like on this asset.
- **3. Policies and law.** Law 25 obliges an organization to keep a register of its confidentiality incidents and, when there is a risk of serious injury, to notify the CAI and the persons concerned. An organization that cannot detect an incident cannot record it or notify anyone: the law itself creates the need “detect unauthorized access to files containing personal information”.

Needs are not invented at a desk

They come from six places, and a thorough identification visits all six:

1. security requirements
2. threats
3. policies and law
4. operational objectives
5. past incidents and the owner's concerns
6. reference lists of recognized bodies



2.4.2 Where monitoring needs come from (2/2)

- **4. Operational objectives.** Preventative monitoring detects problems before they cause damage: a backup that silently fails, a disk that fills up, an Internet link that drops are not attacks, but they are what the owner expects monitoring to notice first.
- **5. Past incidents and the owner's concerns.** Val-des-Pins paid an invoice to a fraudulent account last year after a forged e-mail: two needs on the cloud e-mail service — a sign-in from an unusual location, and a mailbox forwarding rule created without a request.
- **6. Reference lists published by recognized bodies.** They save you from forgetting the ordinary needs.

Reference lists

Links on the HTML page:

Canadian Centre for Cyber Security — Baseline Cyber Security Controls for Small and Medium Organizations (cyber.gc.ca).

CIS Controls — Control 8 audit log management, Control 13 network monitoring and defence (cisecurity.org).

NIST Cybersecurity Framework 2.0 — Detect function, category Continuous Monitoring (nist.gov).

MITRE ATT&CK — data sources in which each attacker technique can be seen (attack.mitre.org).



2.4.3 The method: six questions per asset

#	Question	Column produced	Example: SRV-FILE-01, password guessing
1	What is the asset, and how much does it need confidentiality, integrity and availability?	Asset; criticality	SRV-FILE-01: C 3, I 3, A 3 (quotes, drawings, employee files).
2	What could go wrong on this asset, among the events we know?	Event; requirement harmed	Someone guesses passwords against the server's logon; harms C and I.
3	If it happened, what would we see, with a number or a pattern?	Observable	10 or more failed logons from one source within 5 minutes (Windows Security event 4625).
4	Where would we see it, among the data sources the constraints allow?	Data source	The Windows Security event log, collected by activity A1.
5	How fast must we know?	Detection time objective	15 minutes: ignores one mistyped password, acts before the attacker succeeds.
6	Who must be told, and what happens next?	Recipient; first action	Provider's technician and owner by e-mail; block the source on FW-01, check the account.

Question 4 is where Lesson 2.3 re-enters: a data source exists only if the constraints allow it. When it has no answer, the need is recorded as a gap — never silently dropped.



Figure 3 — The six questions on a covered need and on a gap

Figure 3 — From asset to need: the six questions, applied to a covered need and to a gap

	Covered need N-01	Gap N-13
1. Which asset, how critical?	SRV-FILE-01 — Windows file server C 3, I 3, A 3: quotes, drawings, employee files (Law 25) sources allowed by the register: event log, antivirus, firewall log, availability check	CNC-PC-01 — workshop computer C 1, I 3, A 3: drives two CNC machines sources allowed: firewall log, availability check only
2. What could go wrong?	Password guessing against the server's logon harms C and I → criticality = $\max(3, 3) = 3$ event known from Lesson 1.3 (password attacks)	Password guessing against its logon harms C and I → criticality = $\max(1, 3) = 3$ same event, same importance
3. What would we see?	10 or more failed logons from one source within 5 minutes Windows records each failure as Security event 4625 a number and a pattern: two readers see the same thing	10 or more failed logons within 5 minutes the observable exists on the device... ...but nothing collects it
4. Where would we see it?	Windows Security event log, collected by activity A1 first usable source in the event's list; permitted by the constraints → covered	No usable data source event log blocked by constraints C-04 and C-09 (vendor contract, unsupported Windows 7)
5. How fast must we know?	Within 15 minutes long enough to ignore one mistyped password, short enough to act before the attacker succeeds	Within 15 minutes — cannot be promised compensating measure: FW-01 sees every connection the CNC computer makes (needs N-15 to N-17)
6. Who is told, what happens next?	Provider's technician and owner, by e-mail first action: block the source on FW-01, check the account Lesson 5.5 covers how results are communicated	Owner informed; gap written in the plan weighs in the prioritization of Lesson 2.5; candidate for Lesson 6.3 (improving coverage)

Result of the whole network: 27 needs, 24 covered, 3 gaps (all on CNC-PC-01, all caused by one constraint) — coverage 89 %

Same event, same importance: a data source on the file server, a gap on the workshop computer — the difference is entirely due to constraints C-04 and C-09.



2.4.4 The usual categories of monitoring needs (1/2)

Category	Typical observable	Typical data source	Detection time objective
Authentication	Repeated failed logons; logon at an unusual hour; logon of a disabled account	Windows Security event log; cloud sign-in audit log; VPN log	15 minutes
Accounts and privileges	Account created; account added to an administrators group; password reset by someone else	Windows Security event log; cloud audit log	5 minutes (immediate)
Configuration changes	Firewall rule changed; switch configuration saved; service installed on a server; scheduled task created	Firewall log; switch log; system event log	5 minutes outside a change window
Malware and endpoint protection	Antivirus detection; antivirus disabled or out of date; unexpected program starting at boot	Antivirus console; system event log	15 minutes
Outbound traffic and data movement	Outgoing bytes per host far above the baseline; destinations never seen before; traffic outside hours; workshop device reaching the Internet	Firewall connection log or flow records	1 hour

Use this table as a checklist in Lab 1 so that no category is forgotten; adapt the numbers to the organization. CSV download on the HTML page.



2.4.4 The usual categories of monitoring needs (2/2)

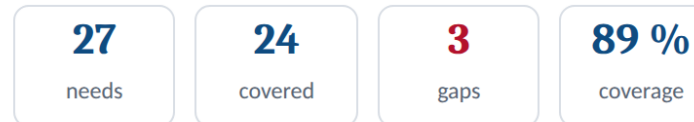
Category	Typical observable	Typical data source	Detection time objective
Unknown devices	DHCP lease granted to a MAC (Media Access Control) address absent from the inventory; new device on the office Wi-Fi	DHCP lease log; access point log	1 hour
Availability of devices and services	No reply to the availability check for 3 consecutive minutes; website returning an error; Internet link down	Availability check (ping, port test, web request)	5 minutes
Capacity	Free disk space below 10 %; processor above 90 % for 10 minutes; link above 80 % of capacity	System event log; SNMP counters; NAS report	1 day for disk; 15 minutes for links
Data protection jobs	Backup job failed, missing or much smaller than usual; restore test failed	NAS or backup software report	12 hours (next morning)
Cloud service accounts	Sign-in from an unusual country; mailbox forwarding rule created; multi-factor authentication disabled	Provider's sign-in and audit logs	1 hour

Availability, capacity and backup needs are not attacks — they are what preventative monitoring notices first (source 4 of 2.4.2).

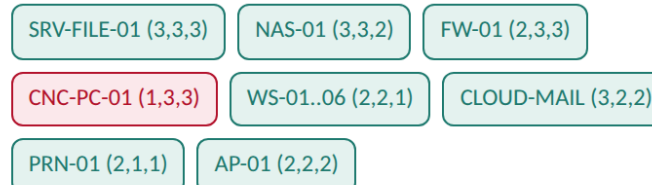


2.4.5 Coverage and gaps

- **Coverage** — the share of needs for which at least one usable data source exists.
- **Gap** — a need with no usable data source, usually because a constraint blocks the source.
- **Coverage matrix** — one row per asset, one column per data source, in each cell the number of needs that source covers on that asset. An empty row or a blocked source is visible at a glance.
- **Every gap is recorded with three things:** the constraint that causes it (its ID), a compensating measure if one exists, and the owner's decision if none exists.
- **Gaps feed** Lesson 2.5 tomorrow (they weigh in the prioritization) and Lesson 6.3 later (improving monitoring coverage).



Assets (question 1) — the one being examined is highlighted



Coverage matrix (question 4): needs covered per asset and data source

asset	evt log	AV	FW log	avail.	NAS	cloud	DHCP	gaps
SRV-FILE-01	3	1	1	1	.	.	.	.
NAS-01	.	.	1	1	2	.	.	.
FW-01	.	.	1	1	.	.	.	.
CNC-PC-01	.	.	2	1	.	.	.	3
WS-01..06	1	1	1	.	.	.	.	.
CLOUD-MAIL	.	.	.	1	.	2	.	.
PRN-01	.	.	.	1	.	.	.	.
AP-01	.	.	.	1	.	.	1	.

The coverage matrix of Val-des-Pins after Program 2: 27 needs, 24 covered, 3 gaps (89 %).



2.4.6 Worked example: three assets by hand

SRV-FILE-01 (3, 3, 3)

Six needs: password guessing, privilege change, malware, data exfiltration, outage, disk almost full.

All covered: event log, antivirus, firewall in front of it, availability check.

CNC-PC-01 (1, 3, 3)

Same list of events.

Malware, exfiltration and outage covered by the firewall log and the availability check.

Password guessing, privilege change, disk almost full: gaps — the only usable sources are outside the device.

CLOUD-MAIL (3, 2, 2)

Password guessing and privilege change through the provider's sign-in audit log.

Outage through an availability check of the service.

Nothing inside the service can be seen: only what the provider exposes (C-12).

Program 2 repeats this reasoning for all eight assets and nine events and produces the full register: 27 needs, 24 covered, 3 gaps.



Real-life example: “What must we watch?”

Task

The owner has accepted the constraints section. Now: what will the monitoring actually tell us?

Take the eight assets and the nine events a small business must expect, apply the six questions to every asset, and produce the needs register, the coverage matrix and the gaps, each tied to its constraint.

Relation to the lesson

Performance criterion 2.2 in practice: needs derived from the assets’ requirements (question 1), the known events (question 2) and the data sources the constraints leave available (question 4).

Deliverable and future labs

Lab 1 (Sept 25): section 4 “Monitoring needs” of the plan.

Lab 2 (Oct 3): every covered need becomes an alert rule (3.5); its observable, a line of the baseline (3.4).

Lab 3 (Oct 16): the anomaly to detect is one of these needs; the gaps open the optimization (6.3).

- **Assets and ratings:** file server (3,3,3), NAS (3,3,2), firewall (2,3,3), CNC computer (1,3,3), six workstations as one group (2,2,1), cloud e-mail (3,2,2), printer (2,1,1), access point (2,2,2).
- **Nine events:** password guessing, privilege change, malware, data exfiltration, outage, backup failure, configuration change, unknown device, disk almost full.



2.4

Program 2 — the six questions, executed

- **ASSETS** — id, type, ratings c/i/a, data sources the constraints allow.
- **THREATS** — requirement harmed, asset types hit, observable, usable sources in order, detection time objective.
- **criticality** — highest rating among the requirements the event harms.
- **usable_source** — first source the event can use that the asset offers; None means a gap.
- **Double loop** — every asset (question 1), every applicable event (question 2), one need per pair; COVERAGE counts the matrix.
- **Output** — register, counts, gaps, matrix, monitoring_needs_register.csv.

27

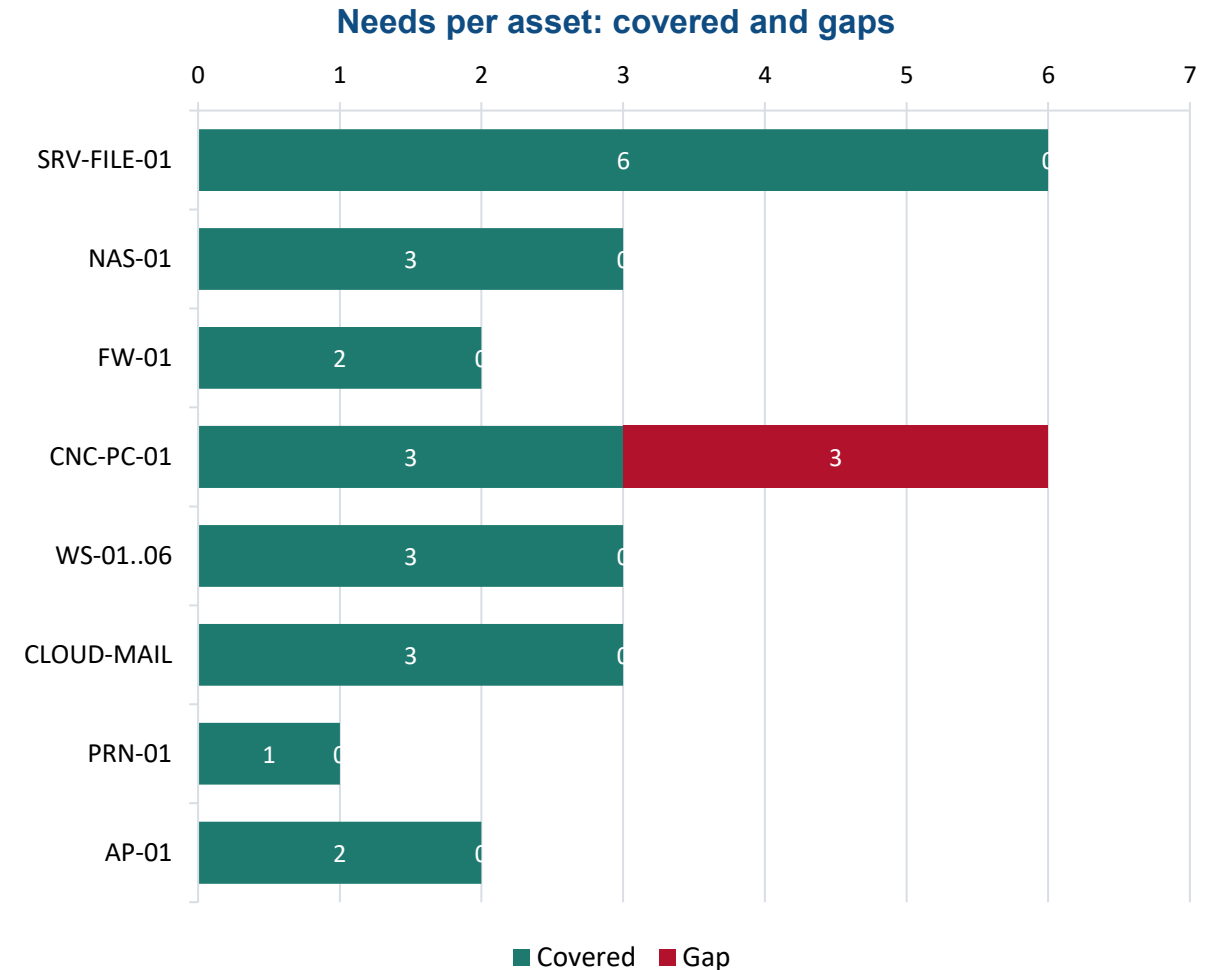
needs

24

covered

3

gaps



Videos for Lesson 2.4 — under 15 minutes each



Security Monitoring — CompTIA Security+ SY0-701 — 4.4

Professor Messer, YouTube, 10 min 27 s

Watch for: what an organization monitors and why — systems, applications, infrastructure, log aggregation, alerting, reporting. Each item corresponds to a row of the categories table (2.4.4).

https://www.youtube.com/watch?v=np2WI_rM-Ok



Log Data — CompTIA Security+ SY0-701 — 4.9

Professor Messer, YouTube, 13 min 41 s

Watch for: the data sources — firewall logs, application logs, endpoint logs, operating-system security logs, network logs, metadata. This is question 4 of the method and a preview of Topic 4.

<https://www.youtube.com/watch?v=EDru1LTyDJw>

Links verified on September 23, 2026. Check any link you did not type yourself with VirusTotal before opening it (Legal Notice, Annex C).

Key terms of Lesson 2.4 (the flash cards)

Term	What it means
Monitoring need	A precise statement of one thing to observe on one asset, for one security or operational reason, with the observable, the data source and the detection time objective. Written before any tool is chosen.
Observable vs data source	The observable is the sign, with a number or a pattern (“10 or more failed logons from one source within 5 minutes”). The data source is where it is recorded (the Windows Security event log).
The six questions	1 which asset, how critical — 2 what could go wrong — 3 what would we see — 4 where, given the constraints — 5 how fast — 6 who is told, what happens next. One column of the register each.
Gap	A need with no usable data source, usually blocked by a constraint. Recorded with the constraint’s ID, a compensating measure if any, and the owner’s decision. Weighs in 2.5; drives 6.3.
Need, alert, tool	The need is the requirement; the alert is the message produced when the observable crosses its threshold (3.5); the tool reads the source and raises the alert (3.2). “Install an antivirus” is a tool, not a need.



Check yourself — Lesson 2.4 (1/2)

1. Which of the following is a correctly written monitoring need?

- a) “Monitor the file server.”
- b) “Install an antivirus on every workstation.”
- c) “On SRV-FILE-01, detect password guessing by observing 10 or more failed logons from one source within 5 minutes in the Windows Security event log, within 15 minutes; notify the provider and the owner.”
- d) “Check the firewall from time to time.”

2. What is a gap in the sense of Lesson 2.4?

- a) A need for which no usable data source can show the observable
- b) An asset that has no name in the inventory
- c) An event that has never happened in the organization
- d) A data source that produces too many events

3. In the six-question method, which question produces the observable?

- a) Question 1 — which asset, how critical
- b) Question 3 — what would we see if it happened
- c) Question 5 — how fast must we know
- d) Question 6 — who must be told

Answers and explanations: in the speaker notes, and on the HTML page (“Check my answer”).



Check yourself — Lesson 2.4 (2/2)

4. Why does CNC-PC-01 produce three gaps in the register?

- a) Because it is not considered an asset
- b) Because constraints C-04 and C-09 prevent collecting its event log, so needs whose only sources are on the device cannot be covered
- c) Because it has no IP address
- d) Because the firewall log does not exist on this network

5. Which are data sources, not observables? (select all that apply)

- a) The Windows Security event log
- b) 10 or more failed logons from one source within 5 minutes
- c) The firewall connection log
- d) Free disk space below 10 %
- e) The cloud provider's sign-in audit log
- f) A backup job missing from the nightly report

6. Which are legitimate sources of monitoring needs? (select all that apply)

- a) The C/I/A rating of each asset
- b) The list of tools the technician prefers
- c) Law 25's obligations on confidentiality incidents
- d) The colour of the network cables
- e) The forged-invoice e-mail incident of last year
- f) The number of ports on SW-02

Answers and explanations: in the speaker notes, and on the HTML page ("Check my answer").



C7 Tomorrow: Lesson 2.5 and Lab 1 — what to bring

Bring to Lab 1	Where it comes from
Your network map and inventory	Class 5 (Lessons 2.1 and 2.2), for your own fictional organization or for Val-des-Pins.
Your constraint register	Tonight, Lesson 2.3: eight columns, one line per fact, hard or soft, impact 1 to 3, adaptation. Start from the CSV template.
Your needs register and coverage matrix	Tonight, Lesson 2.4: one line per asset and event, six answers per line, gaps tied to a constraint ID.
The two programs, run once in your lab virtual machine	Download the .py files from the HTML page, run them inside your Authorized Lab Environment, keep the two CSV files they produce.

Required resources: your free BAnQ account (O'Reilly, LinkedIn Learning) and the Institutional Student Evaluation Policy (ISEP) — links on the HTML page.

Class 7 — Friday, September 25

6:00 pm, online. Lesson 2.5, prioritizing monitoring activities, then Lab 1 (5 %): map a small network and write its monitoring plan.

Quiz 2 — Saturday, September 26

5 %, cumulative: Topics 1 and 2, plus Lessons 3.1 and 3.2 given the same afternoon.

Midterm — Thursday, October 1

25 %, in class, Topics 1 to 3.



Links used in this class (1/2): legal framework and institutions

[Cyber.SoHo Legal Notice, Terms of Use and AUP v2.0](#)

Sections 6.1, 6.4, 6.7, 7.2, Annex D, Annex E apply to this class. — <https://cyber-soho.github.io/prevmon/00.01.cyber.soho-legal.html>

[Criminal Code of Canada](#)

Sections 184, 342.1, 342.2, 430(1.1). — <https://laws-lois.justice.gc.ca/eng/acts/c-46/>

[Act respecting the protection of personal information in the private sector \(Law 25\)](#)

Québec private-sector privacy law. — <https://www.legisquebec.gouv.qc.ca/en/document/cs/P-39.1>

[Commission d'accès à l'information du Québec](#)

Supervises personal-information obligations; receives incident notifications. — <https://www.cai.gouv.qc.ca/>

[Office of the Privacy Commissioner of Canada](#)

PIPEDA, the federal private-sector privacy law. — <https://www.priv.gc.ca/>

[Canada's Anti-Spam Legislation \(CASL\)](#)

Section 8: installing software without express consent. — <https://ised-isde.canada.ca/site/canada-anti-spam-legislation/>

[Dawson College — and the ISEP](#)

The college delivering the LEA.D8 program. — <https://www.dawsoncollege.qc.ca/>

[BANQ — free account](#)

Access to O'Reilly and LinkedIn Learning (required by the outline). — <https://cap.banq.qc.ca/inscription?locale=en>



Links used in this class (2/2): references, videos and tools

[Canadian Centre for Cyber Security — Baseline controls for small and medium organizations](#)

Source of ordinary monitoring needs (2.4.2). — <https://www.cyber.gc.ca/en/guidance/baseline-cyber-security-controls-small-and-medium-organizations>

[CIS Controls](#)

Control 8 audit log management; Control 13 network monitoring and defense. — <https://www.cisecurity.org/controls>

[NIST Cybersecurity Framework](#)

Detect function, Continuous Monitoring. — <https://www.nist.gov/cyberframework>

[MITRE ATT&CK](#)

Attacker techniques and the data sources that reveal them. — <https://attack.mitre.org/>

[ISO/IEC 27001](#)

Information-security management standard (licensed document). — <https://www.iso.org/standard/27001>

[Professor Messer — free Security+ course index](#)

Index and durations of the four recommended videos. — <https://www.professormesser.com/security-plus/sy0-701/sy0-701-video/sy0-701-comptia-security-plus-course/>

[VirusTotal — URL scanner](#)

Check every link before opening it (Annex C). — <https://www.virustotal.com/gui/home/url>

[Google Safe Browsing](#)

Second opinion on a domain (Annex C). — <https://transparencyreport.google.com/safe-browsing/search>

[The NTP Project, Wireshark, Microsoft Learn, Python](#)

Lab resources: ntp.org, wireshark.org, learn.microsoft.com, python.org. — <https://www.ntp.org/>





Two registers, one plan

What limits us — the constraint register (Lesson 2.3).

What we must watch — the needs register and its gaps (Lesson 2.4).

Tomorrow: what comes first — prioritization (Lesson 2.5) and Lab 1.

Educational material — Cyber.SoHo / Asen Grozdanov. © 2026 Cyber.SoHo. All rights reserved. For use in an isolated, authorized lab environment only, against the targets this exercise designates. Applying these tools or techniques to any other system, network or data without the owner's express written authorization may be a criminal offence (Criminal Code, ss. 342.1, 342.2, 430(1.1) and 184) and is strictly prohibited. You alone are responsible for your actions and your equipment.

Full terms: Cyber.SoHo Legal Notice, Terms of Use and Acceptable Use Policy, v2.0 — <https://cyber-soho.github.io/prevmon/00.01.cyber.soho-legal.html>

